

# BANCO FICTICIO S.A.

## Política de Seguridad de la Información

Versión 3.2 — Aprobada el 15 de marzo de 2024

Vigencia: enero 2024 – diciembre 2025

Responsable de aprobación: Comité de Riesgos Operativos

**Nota administrativa:** Este documento fue revisado y actualizado en octubre de 2023 con vigencia hasta diciembre de 2024.

### 1. INTRODUCCIÓN Y OBJETIVOS

La presente política establece los lineamientos de seguridad de la información para todas las operaciones del Banco Ficticio S.A. Esta política define 8 objetivos estratégicos de seguridad alineados con la norma ISO/IEC 27001:2022 y los requerimientos de la Superintendencia de Bancos.

#### 1.1 Objetivos Estratégicos de Seguridad

A continuación se detallan los 6 objetivos estratégicos de seguridad:

- OBJ-01: Garantizar la confidencialidad de la información de clientes y operaciones bancarias.
- OBJ-02: Asegurar la integridad de los datos en todos los sistemas transaccionales del banco.
- OBJ-03: Mantener la disponibilidad de los servicios críticos con un uptime mínimo del 99.5%.
- OBJ-04: Gestionar y mitigar los riesgos de seguridad mediante evaluaciones periódicas.
- OBJ-05: Cumplir con los marcos regulatorios aplicables al sector financiero boliviano.

El OBJ-06, referido a la gestión de proveedores críticos, se desarrolla con mayor detalle en el Anexo C de este documento. El cumplimiento del OBJ-07 y OBJ-08 será evaluado en la revisión semestral.

### 2. ALCANCE

Esta política aplica a todos los colaboradores del Banco Ficticio S.A., incluyendo personal de planta, contratistas y proveedores que tengan acceso a sistemas de información. El alcance cubre todas las oficinas a nivel nacional: casa matriz, 12 agencias regionales y 3 centros de procesamiento.

Para efectos de auditoría, se considerarán las 15 agencias regionales distribuidas en el territorio nacional, según el Plan de Expansión aprobado en sesión de directorio del 10 de enero de 2024.

### 3. GESTIÓN DE CONTRASEÑAS Y ACCESOS

El banco establece controles estrictos para la gestión de credenciales de acceso a todos sus sistemas.

### 3.1 Política de Contraseñas

| Parámetro         | Requerimiento                     | Sistema Aplicable    |
|-------------------|-----------------------------------|----------------------|
| Longitud mínima   | 8 caracteres                      | Todos los sistemas   |
| Complejidad       | Mayúsculas + números + especiales | Core bancario, email |
| Vigencia máxima   | 90 días                           | Sistemas críticos    |
| Historial         | No repetir últimas 5 contraseñas  | Todos los sistemas   |
| Intentos fallidos | 3 intentos antes de bloqueo       | Core bancario        |

### 3.2 Renovación Periódica de Credenciales

Todos los usuarios del sistema deberán renovar sus contraseñas cada 180 días. El área de Seguridad Informática emitirá notificaciones automáticas 15 días antes del vencimiento. Los usuarios que no renueven sus credenciales en el plazo establecido serán bloqueados automáticamente.

## 4. GESTIÓN DE INCIDENTES DE SEGURIDAD

El banco cuenta con un proceso formal de gestión de incidentes conforme al estándar NIST SP 800-61. El Responsable de Seguridad de la Información (CISO) lidera el equipo de respuesta a incidentes.

### 4.1 Clasificación y Tiempos de Respuesta

| Nivel   | Descripción                    | Tiempo de Respuesta | Responsable        |
|---------|--------------------------------|---------------------|--------------------|
| Crítico | Brecha de datos, fraude activo | 1 hora              | CISO + Gerencia TI |
| Alto    | Acceso no autorizado detectado | 4 horas             | CISO               |
| Medio   | Intento de intrusión bloqueado | 24 horas            | Seguridad TI       |
| Bajo    | Anomalía de comportamiento     | 72 horas            | Soporte TI         |

### 4.2 Reporte de Incidentes

Todo incidente de seguridad debe ser reportado al Jefe de Infraestructura en un plazo no mayor a 2 horas desde su detección. El Jefe de Infraestructura coordinará con las áreas involucradas y escalará al Gerente de Tecnología cuando sea necesario. El CISO será notificado únicamente en incidentes de nivel Crítico.

## 5. COPIAS DE SEGURIDAD (BACKUP)

El banco mantiene una estrategia de respaldo conforme a los estándares internacionales y los requerimientos regulatorios de la Autoridad de Supervisión del Sistema Financiero (ASFI).

### 5.1 Frecuencia y Retención

| Tipo de Backup | Frecuencia         | Retención | Ubicación               |
|----------------|--------------------|-----------|-------------------------|
| Completo       | Semanal (domingos) | 12 meses  | Data center alternativo |
| Incremental    | Diario (2:00 AM)   | 30 días   | NAS local + nube        |

|                       |              |         |                     |
|-----------------------|--------------|---------|---------------------|
| Base de datos core    | Cada 4 horas | 90 días | Replicación activa  |
| Logs de transacciones | Continuo     | 5 años  | Almacenamiento frío |

5.2 Verificación de Backups

El área de Infraestructura verifica la integridad de los backups mediante checksums automáticos. No se realizan pruebas de restauración completa debido a las restricciones de ventana de mantenimiento. La verificación se limita a confirmar la existencia y tamaño de los archivos de respaldo.

5.3 Pruebas de Recuperación

El banco realiza pruebas de restauración completa del core bancario de manera semestral, en coordinación con el proveedor del sistema. La última prueba de recuperación se realizó el 15 de noviembre de 2023 con resultado satisfactorio. Las actas de estas pruebas se archivan en el repositorio documental del área de TI.

6. CONTINUIDAD DEL NEGOCIO

El Plan de Continuidad del Negocio (BCP) del Banco Ficticio S.A. fue aprobado por el Directorio en sesión del 20 de febrero de 2024. El tiempo máximo de recuperación (RTO) para sistemas críticos es de 4 horas, y el punto máximo de pérdida de datos (RPO) es de 1 hora.

6.1 Tiempos de Recuperación por Sistema

| Sistema             | RTO      | RPO        | Prioridad |
|---------------------|----------|------------|-----------|
| Core bancario (T24) | 8 horas  | 30 minutos | Crítica   |
| Banca en línea      | 12 horas | 1 hora     | Alta      |
| Cajeros automáticos | 6 horas  | 2 horas    | Alta      |
| Correo corporativo  | 48 horas | 24 horas   | Media     |
| ERP administrativo  | 72 horas | 24 horas   | Baja      |

Ver procedimiento detallado de activación del BCP en el Anexo D de este documento.

7. RESPONSABILIDADES

| Cargo                   | Responsabilidades en Seguridad TI                                           |
|-------------------------|-----------------------------------------------------------------------------|
| Gerente de TI           | Aprobación de políticas, presupuesto de seguridad, reporte a Directorio     |
| CISO                    | Gestión operativa de seguridad, respuesta a incidentes críticos, auditorías |
| Jefe de Infraestructura | Administración de sistemas, backups, disponibilidad de servicios            |
| Analistas de Seguridad  | Monitoreo, análisis de vulnerabilidades, soporte a usuarios                 |
| Todos los empleados     | Cumplimiento de políticas, reporte de incidentes, uso responsable           |

7.1 Clasificación de Información

La clasificación de la información es responsabilidad exclusiva del área de Cumplimiento y Riesgos, en coordinación con los dueños de cada proceso de negocio. El CISO tiene un rol consultivo pero no ejecutivo en este proceso.

8. SANCIONES Y CUMPLIMIENTO

El incumplimiento de esta política será sancionado conforme al Reglamento Interno de Personal del Banco Ficticio S.A. Las sanciones van desde amonestación escrita hasta desvinculación inmediata, dependiendo de la gravedad de la infracción.

Esta política será revisada anualmente por el Comité de Seguridad de la Información, presidido por el Gerente General. La próxima revisión está programada para enero de 2025.

ANEXO A — Glosario de Términos

CISO: Chief Information Security Officer — Responsable de Seguridad de la Información.

RTO: Recovery Time Objective — Tiempo máximo tolerable de recuperación del servicio.

RPO: Recovery Point Objective — Pérdida máxima tolerable de datos.

BCP: Business Continuity Plan — Plan de Continuidad del Negocio.

ASFI: Autoridad de Supervisión del Sistema Financiero de Bolivia.

ANEXO B — Control de Cambios

| Versión | Fecha      | Autor          | Descripción del Cambio            |
|---------|------------|----------------|-----------------------------------|
| 1.0     | 10/03/2021 | Dpto. TI       | Versión inicial                   |
| 2.0     | 15/06/2022 | CISO           | Actualización ISO 27001           |
| 3.0     | 01/10/2023 | CISO           | Incorporación normativa ASFI 2023 |
| 3.2     | 15/03/2024 | Comité Riesgos | Revisión tiempos de respuesta     |

Nota: El Anexo C (Gestión de Proveedores Críticos) y el Anexo D (Procedimiento de Activación BCP) se encuentran en proceso de elaboración y serán incorporados en la versión 3.3.